

Annual Re-Assessment & Updated AOC

Document ID	Version	Owner	Effective Date	Framework	Classification
[DOC-ID]	1.0	[Compliance Owner / CISO]	[Effective Date]	PCI DSS v4.0.1	Confidential

Purpose

This attestation confirms that [Organisation Name] has completed its annual PCI DSS re-assessment and has prepared an updated Attestation of Compliance for the current assessment period.

The purpose of this document is to provide management, acquiring banks, payment brands, customers, auditors, and other authorised stakeholders with a formal statement that:

- The cardholder data environment has been re-validated for the assessment year.
- The current scope of PCI DSS applicability has been reviewed and confirmed.
- Required assessment activities have been completed using the appropriate PCI DSS v4.0.1 validation method.
- Supporting evidence has been collected, reviewed, and retained.
- The updated Attestation of Compliance accurately reflects the organisation's compliance status as of the assessment date.
- Any identified gaps, compensating controls, remediation actions, or residual risks have been documented and approved through the organisation's governance process.

This attestation is intended to support the annual compliance cycle and does not replace the formal Attestation of Compliance, Self-Assessment Questionnaire, Report on Compliance, or any other validation artefact required by acquiring banks, payment brands, or contractual obligations.

Scope

This attestation applies to the annual re-assessment of [Organisation Name]'s PCI DSS environment for the assessment period covering [Assessment Start Date] to [Assessment End Date].

The scope includes all people, processes, technologies, facilities, service providers, and network segments that store, process, transmit, or can impact the security of cardholder data or sensitive authentication data.

The following scope elements were reviewed as part of the annual re-assessment:

Scope Area	Included in Re-Assessment	Description / Notes
Cardholder data environment	Yes	Systems, applications, databases, network components, and security services involved in cardholder data processing.
Connected-to and security-impacting systems	Yes	Systems that could affect the security of the cardholder data environment, including identity services, logging, monitoring, vulnerability management, and administrative access platforms.
Payment channels	Yes	[E-commerce / mail order / telephone order / in-person / recurring billing / other applicable channels].
Payment applications	Yes	[Payment application names or descriptions].
Network segmentation controls	Yes	Firewalls, access control lists, segmentation testing, routing controls, and supporting documentation.
Cloud and hosted environments	[Yes / No / Not Applicable]	[Cloud providers, hosting locations, managed platforms, or shared responsibility boundaries].

Scope Area	Included in Re-Assessment	Description / Notes
Third-party service providers	Yes	Service providers that store, process, transmit, or can affect the security of account data.
Physical locations	[Yes / No / Not Applicable]	[Data centres, offices, call centres, retail sites, storage locations, or other relevant facilities].
Policies, standards, and procedures	Yes	Governance documents supporting the PCI DSS control environment.
Security operations processes	Yes	Monitoring, logging, incident response, vulnerability management, change management, access management, and secure configuration processes.
Personnel with PCI DSS responsibilities	Yes	Employees, contractors, administrators, developers, support teams, service owners, and compliance stakeholders.

The following environments, systems, or services were excluded from the assessment scope based on documented scoping analysis:

Excluded Item	Reason for Exclusion	Validation Performed
[System / environment / location]	[No storage, processing, transmission, or security impact on account data]	[Segmentation review / data flow review / architecture review / management confirmation]
[System / environment / location]	[Reason]	[Validation activity]

The annual scope review considered:

- Current cardholder data flows.
- Network diagrams and system inventories.
- Payment processing methods and channels.
- Data storage locations and retention practices.
- Administrative access paths.
- Remote access methods.
- Security monitoring and logging coverage.
- Encryption and key management practices.
- Vulnerability management and penetration testing results.
- Changes to systems, applications, service providers, architecture, or business processes since the prior assessment.
- Applicability of any compensating or alternative controls.
- Service provider responsibilities and current compliance status.

Attestation Statement

On behalf of [Organisation Name], the undersigned attests that an annual re-assessment of the organisation's PCI DSS environment has been completed for the assessment period ending [Assessment End Date].

Based on the assessment activities performed, evidence reviewed, and management representations obtained, [Organisation Name] attests that:

- The scope of the cardholder data environment has been reviewed, validated, and documented.
- Cardholder data flows have been reviewed and confirmed as current.

- System inventories, network diagrams, and security architecture documentation have been reviewed and updated where necessary.
- The applicable PCI DSS v4.0.1 validation method has been completed for the organisation's merchant, service provider, and payment environment profile.
- The updated Attestation of Compliance has been prepared and reviewed for accuracy.
- All in-scope systems, processes, and control owners were included in the assessment activities applicable to their responsibilities.
- Third-party service provider reliance has been reviewed, and current compliance evidence has been obtained or formally risk-assessed where evidence was unavailable or incomplete.
- Evidence supporting the assessment has been retained in accordance with the organisation's records retention requirements.
- Any control gaps or remediation items identified during the assessment have been documented, assigned to accountable owners, and tracked through governance oversight.
- Where compensating or alternative controls are used, they have been documented, justified, approved, and supported by evidence demonstrating that the intended security outcome is achieved.
- No known material misstatement has been included in the updated Attestation of Compliance.
- No known cardholder data environment component has been intentionally omitted from the assessment scope.
- Management has reviewed the results of the annual re-assessment and accepts responsibility for maintaining PCI DSS compliance throughout the year.

The annual re-assessment outcome is recorded as follows:

Assessment Item	Result
Assessment period	[Assessment Start Date] to [Assessment End Date]
Assessment completion date	[Completion Date]
Validation type	[SAQ / ROC / Other validation method]
Assessment performed by	[Internal Assessor / Qualified Security Assessor / Internal Security Assessor / Other]
Compliance status	[Compliant / Compliant with documented remediation plan / Not compliant pending remediation]
Updated AOC prepared	[Yes / No]
Updated AOC approved	[Yes / No / Pending]
Updated AOC submission required	[Yes / No]
Submission recipient	[Acquirer / Payment Brand / Customer / Other]
Submission due date	[Due Date]
Material scope changes since prior assessment	[Yes / No]
Open remediation items	[Number]
Approved compensating or alternative controls	[Number / None]
Management acceptance obtained	[Yes / No]

Where the assessment status is not fully compliant, this attestation confirms that the organisation has documented the outstanding items and is managing remediation through an approved corrective action plan.

Remediation Item	Risk Rating	Owner	Target Completion Date	Current Status
[Issue or gap summary]	[High / Medium / Low]	[Owner]	[Date]	[Open / In Progress / Completed / Risk Accepted]
[Issue or gap summary]	[High / Medium / Low]	[Owner]	[Date]	[Open / In Progress / Completed / Risk Accepted]

This attestation remains valid only for the assessment state represented by the evidence reviewed as of [Assessment Completion Date]. Significant changes to the cardholder data environment, payment processes, service provider arrangements, security architecture, or control operation may require re-validation before the next scheduled annual assessment.

Signatory & Authority

The individuals below have authority to approve this attestation and confirm the accuracy of the annual re-assessment statements within their areas of responsibility.

Role	Name	Responsibility	Signature	Date
Executive Sponsor	[Name]	Confirms executive accountability for PCI DSS compliance and approves submission of the updated AOC where required.	[Signature]	[Date]
Chief Information Security Officer / Security Lead	[Name]	Confirms security control oversight, assessment coordination, and remediation governance.	[Signature]	[Date]
Compliance Owner	[Name]	Confirms assessment evidence, compliance documentation, and AOC preparation have been completed.	[Signature]	[Date]
Payment Operations Owner	[Name]	Confirms payment processes, channels, and operational responsibilities are accurately represented.	[Signature]	[Date]
Technology Owner	[Name]	Confirms in-scope systems, infrastructure, architecture, and technical control evidence are accurate.	[Signature]	[Date]
Assessor, where applicable	[Name / Firm]	Confirms assessment activities were performed and results recorded in the relevant validation artefacts.	[Signature]	[Date]

By signing this attestation, each signatory confirms that, to the best of their knowledge:

- Information provided for the annual re-assessment is complete and accurate.
- Relevant changes during the assessment period have been disclosed.
- Known gaps, exceptions, and remediation actions have not been concealed.
- Supporting evidence has been made available for review.
- The updated Attestation of Compliance reflects the current compliance status of the organisation.
- Ongoing compliance responsibilities will continue to be performed after the annual assessment date.

Delegated approval may be accepted only where formally authorised by [Organisation Name]'s governance process. Delegated signatories must have sufficient knowledge of the relevant PCI DSS responsibilities and the authority to approve the attestation on behalf of the accountable role.

Evidence Referenced

The annual re-assessment and updated Attestation of Compliance were supported by the following evidence categories.

Evidence Category	Evidence Reviewed	Evidence Owner	Repository / Location	Review Status
Current Attestation of Compliance	Updated AOC for the assessment period	[Compliance Owner]	[Repository / path]	[Reviewed / Pending]
Assessment workbook or questionnaire	Completed validation responses and assessor notes	[Compliance Owner]	[Repository / path]	[Reviewed / Pending]
Cardholder data flow diagrams	Current diagrams showing storage, processing, and transmission of account data	[Architecture Owner]	[Repository / path]	[Reviewed / Pending]
Network diagrams	Current network and segmentation diagrams for in-scope environments	[Network Owner]	[Repository / path]	[Reviewed / Pending]
Asset inventory	In-scope systems, applications, databases, network devices, and security tools	[Technology Owner]	[Repository / path]	[Reviewed / Pending]
Data inventory	Locations and retention periods for account data	[Data Owner]	[Repository / path]	[Reviewed / Pending]
Segmentation validation	Segmentation test results and firewall rule reviews	[Network Security Owner]	[Repository / path]	[Reviewed / Pending]
Vulnerability management evidence	Internal and external vulnerability scans, remediation records, and scan attestations	[Security Operations Owner]	[Repository / path]	[Reviewed / Pending]
Penetration testing evidence	Penetration test reports, scope statements, remediation evidence, and retest results	[Security Testing Owner]	[Repository / path]	[Reviewed / Pending]
Secure configuration evidence	Configuration standards, baseline reviews, hardening evidence, and exception records	[Infrastructure Owner]	[Repository / path]	[Reviewed / Pending]
Access management evidence	User access reviews, privileged access records, authentication settings, and joiner-mover-leaver samples	[Identity Owner]	[Repository / path]	[Reviewed / Pending]
Logging and monitoring evidence	Log source inventory, alerting procedures, monitoring samples, and retention evidence	[Security Operations Owner]	[Repository / path]	[Reviewed / Pending]
Incident response evidence	Incident response plan, testing records, contact lists, and post-incident review records	[Incident Response Owner]	[Repository / path]	[Reviewed / Pending]
Change management evidence	Change records for in-scope systems and security-impacting changes	[Change Manager]	[Repository / path]	[Reviewed / Pending]
Cryptography and key management evidence	Encryption design, certificate records, key management procedures, and key rotation evidence	[Cryptography Owner]	[Repository / path]	[Reviewed / Pending]
Secure development evidence	Secure coding standards, code review records, application testing, and release approvals	[Application Owner]	[Repository / path]	[Reviewed / Pending]
Service provider evidence	Current AOCs, responsibility matrices, contracts, and monitoring records	[Third-Party Risk Owner]	[Repository / path]	[Reviewed / Pending]
Policy and procedure evidence	Approved PCI DSS-related policies, standards, and operational procedures	[Policy Owner]	[Repository / path]	[Reviewed / Pending]
Training and awareness evidence	Security awareness records and role-based training completion evidence	[Training Owner]	[Repository / path]	[Reviewed / Pending]
Risk and exception records	Approved exceptions, compensating controls, alternative control documentation, and residual risk approvals	[Risk Owner]	[Repository / path]	[Reviewed / Pending]

Evidence Category	Evidence Reviewed	Evidence Owner	Repository / Location	Review Status
Management review records	Meeting minutes, approval records, dashboards, and remediation tracking reports	[Compliance Owner]	[Repository / path]	[Reviewed / Pending]

Evidence must be sufficient to demonstrate that controls were in place and operating as represented during the assessment period. Evidence should be traceable to the relevant system, process, owner, date, and assessment activity.

The following evidence quality expectations apply:

- Evidence must be current for the assessment period.
- Evidence must be complete and unaltered.
- Screenshots must show relevant system names, timestamps, settings, and user context where appropriate.
- Reports must identify the assessed scope, date performed, methodology, results, and remediation status.
- Sampling must be documented where not every item is reviewed.
- Assessor requests, management responses, and evidence submissions must be retained.
- Evidence supporting exclusions from scope must be clear and defensible.
- Service provider evidence must be current and aligned to the services relied upon by [Organisation Name].
- Remediation evidence must show both correction and validation of effectiveness.
- Exceptions must include business justification, risk assessment, expiry date, and approval.

Frequency

The annual PCI DSS re-assessment and updated Attestation of Compliance must be completed at least once every twelve months, or more frequently where required by acquiring banks, payment brands, customer contracts, material business change, or significant change to the cardholder data environment.

The annual cycle is managed according to the following indicative timeline:

Activity	Target Timing	Accountable Owner	Output
Confirm assessment approach and required validation type	120 days before due date	[Compliance Owner]	Assessment plan and stakeholder list
Refresh scope and cardholder data flows	100 days before due date	[Architecture Owner]	Updated scope record and data flow diagrams
Confirm in-scope systems and service providers	90 days before due date	[Technology Owner / Third-Party Risk Owner]	Updated inventory and service provider register
Collect preliminary control evidence	75 days before due date	[Control Owners]	Evidence package
Complete technical testing and remediation checks	60 days before due date	[Security Operations Owner]	Scan, test, and remediation records
Perform assessor review or internal validation	45 days before due date	[Assessor / Compliance Owner]	Assessment findings and evidence requests
Resolve evidence gaps and control issues	30 days before due date	[Control Owners]	Remediation evidence and updated tracking
Prepare updated AOC and related validation artefacts	20 days before due date	[Compliance Owner]	Draft AOC and assessment package
Management review and approval	10 days before due date	[Executive Sponsor]	Signed attestation and approval record
Submit updated AOC where required	By due date	[Compliance Owner]	Submission confirmation
Conduct post-assessment lessons learned	Within 30 days after submission	[Compliance Owner]	Improvement actions for next cycle

A re-assessment, partial reassessment, or management review must be triggered before the next annual cycle if any of the following occur:

- A new payment channel is introduced.
- Cardholder data storage, processing, or transmission changes materially.
- A major system, application, hosting platform, or network architecture change is implemented.
- Network segmentation controls are redesigned or materially changed.
- A new third-party service provider is engaged for payment or security-impacting services.
- A service provider's compliance status changes materially.
- A significant security incident affects or may affect the cardholder data environment.
- A material vulnerability or control failure is identified.
- A merger, acquisition, outsourcing arrangement, or divestment affects the cardholder data environment.
- An acquiring bank, payment brand, customer, or regulator requests updated validation.

Ownership for ongoing compliance between annual assessments remains with the accountable control owners. Annual re-assessment is not a substitute for continuous control operation, monitoring, vulnerability management, change governance, or risk management.

Records & Retention

[Organisation Name] must retain records supporting the annual re-assessment and updated Attestation of Compliance in a secure, access-controlled repository.

The following records must be retained:

Record Type	Minimum Retention Period	Record Owner	Storage Location	Access Restrictions
Signed attestation document	[Retention Period]	[Compliance Owner]	[Repository / path]	Compliance, Security, Audit, Executive Management
Updated Attestation of Compliance	[Retention Period]	[Compliance Owner]	[Repository / path]	Compliance, Security, Audit, Executive Management
Completed assessment questionnaire or report	[Retention Period]	[Compliance Owner]	[Repository / path]	Compliance, Security, Audit, Assessor
Evidence package	[Retention Period]	[Compliance Owner]	[Repository / path]	Authorised assessment stakeholders only
Scope documentation	[Retention Period]	[Architecture Owner]	[Repository / path]	Compliance, Security, Architecture
Data flow diagrams and network diagrams	[Retention Period]	[Architecture Owner]	[Repository / path]	Compliance, Security, Architecture, Network Teams
Service provider compliance evidence	[Retention Period]	[Third-Party Risk Owner]	[Repository / path]	Compliance, Legal, Security, Third-Party Risk
Remediation and exception records	[Retention Period]	[Risk Owner]	[Repository / path]	Compliance, Security, Risk Owners
Management approval records	[Retention Period]	[Compliance Owner]	[Repository / path]	Compliance, Audit, Executive Management
AOC submission confirmations	[Retention Period]	[Compliance Owner]	[Repository / path]	Compliance, Legal, Executive Management

Records must be protected against unauthorised access, alteration, deletion, and disclosure. Because PCI DSS evidence may include sensitive system configuration details, vulnerability information, network diagrams, security procedures, and payment environment details, access must be limited to personnel with a legitimate business need.

Records must be managed according to the following requirements:

- Store final approved records separately from working drafts.
- Maintain evidence integrity, including original file names, timestamps, and source information where practical.
- Retain assessor communications and evidence request logs where they support assessment conclusions.
- Retain approvals for scope decisions, exclusions, compensating controls, alternative controls, and exceptions.
- Retain remediation evidence and closure approvals for issues identified during the assessment.
- Retain submission confirmations where the AOC is provided to an acquiring bank, payment brand, customer, or other authorised party.
- Do not store sensitive authentication data as part of assessment evidence.
- Redact account data from evidence unless explicitly required and approved for assessment purposes.
- Encrypt repositories containing sensitive assessment evidence where supported by the storage platform.
- Review access to the evidence repository at least annually and upon personnel role changes.
- Dispose of expired records securely in accordance with [Organisation Name]'s information retention and disposal requirements.

The Compliance Owner is responsible for confirming that the final signed attestation, updated AOC, and supporting assessment records are complete, approved, securely stored, and available for authorised audit or stakeholder review.